NovaBridge Financial Services Pvt. Ltd.

KYC-Pro Solutions

Onboarding Assessment Summary

Vendor ID: V02

Service Provided: Real-time KYC verification

Document owner: <Your name>, GRC Analyst

Assessment Date: 11-04-2026

Next Review Date: 90 days from approval date

Risk Tier: High

Approval Authority: Priya Nair, Head of GRC

Version Control:

Version no.	Creation/Changes made	Approved By
1.0	Onboarding assessment summary document created	Head of GRC

Executive Summary:

- The onboarding assessment of KYC-Pro Solutions was conducted to evaluate its security, compliance, and operational posture. The vendor demonstrates a generally acceptable level of control maturity; however, certain gaps were identified in areas such as **access control, fourth-party risk, formal risk assessment process, employee background check**.
- Based on the assessment, the vendor is classified **High risk**, and onboarding is **Approved with conditions**, subject to remediation of identified risks.

Scope of Assessment:

- Domains covered:
    - Company Information
    - Data Security
    - Access Control
    - Incident Management
    - Business Continuity
    - Compliance
    - Subcontractors
    - Data Handling

Summary of Findings:

- **<u>Satisfactory Findings</u>**
    - Business is registered and have a license
    - Have formal information security policy
    - Encryption methods are used. AES-256 for data at rest. TLS 1.2 for data in transit.
    - Role-based access control (RBAC) implemented across all systems.
    - Access rights reviewed every 6 months. Revocation done upon resignation
    - Incidents are logged in their ITSM tool, triaged by the security team, and escalated based on severity.
    - BCP documented and approved by senior management — tested annually per vendor confirmation
    - Data retention policy in place
    - Secure Deletion post termination
    - Only necessary data is collected and processed
    - Annual Employee training conducted

- **<u>Clarifications Required</u>**
    - Vendor client names under NDA

    - Last Pentest was conducted 14 months ago, which is more than 1 year; and is conducted by internal team which is not acceptable for HIGH risk vendor
    - Weekly log review is insufficient, it should be real-time or daily at minimum
    - Breach notification timeline is 7days, it should be maximum 72 hours
    - Disaster Recovery is untested for 26 months which is more than 2 years, annual testing is standard
    - Request confirmation and evidence of DPDP Act compliance completion, as the Q3 2025 deadline has passed
    - ISO 27001 certificate expiry must be confirmed. SOC 2 Type II not yet available, Provide interim controls summary
    - Asset inventory is reviewed annually, but it must be accurate and complete
    - RPO of 24 hours means up to full day of data loss, which is unacceptable for live transaction data

- **Red Flags**
    - There is no MFA implemented for standard users
    - No formal security assessment conducted for TextScan, this is a fourth-party risk gap
    - Background check is conducted only for employees in sensitive role which is around 40% of staff, it must be conducted for all employees
    - No fixed Risk assessment schedule
    - IRP requires immediate review and update to reflect current regulatory obligations

Recommendations

- **Conditional Approval** — KYC-Pro Solutions may be onboarded subject to resolution of the following pre-conditions before go-live:
    - MFA enabled for all user accounts (not just admins)
    - Formal security assessment of TextScan completed and shared
    - Background checks extended to 100% of staff with data access
    - ISO 27001 renewal confirmation obtained
    - Breach notification SLA contractually fixed at 72 hours
    - Fixed periodic risk assessment schedule established (minimum annual)
    - RTO/RPO renegotiated for Critical tier SLA alignment

- **Post-onboarding conditions** (within 90 days):
    - DR test completed and results shared
    - Pentest by independent third-party firm conducted
    - IRP updated and shared